

Phishing Email Detection

Project Analysis Report

Comparative Evaluation of Rule-Based, ML-Based, URL-Based, and Hybrid Approaches

Marta Kotłowska
Maciej Jurczyk

1. Project Overview

This project implements and evaluates phishing email detection systems on a shared labelled dataset.

Six detector configurations are compared:

- Rule-Based Detector — weighted pattern-matching engine over email body text
- HuggingFace (BERT) Detector — fine-tuned BERT model from the Hugging Face Hub
- URL Analyzer — heuristic scorer that extracts and evaluates URLs found in the email body
- Hybrid (Weighted) — weighted ensemble of all three (0.20 / 0.55 / 0.25), threshold 0.45
- Strict Hybrid — consensus voting: phishing only when at least 2 of 3 detectors exceed 0.35
- Hybrid (Rule+URL) — excludes BERT; combines rule-based (0.60) and URL (0.40) as an ablation study

2. Dataset

The dataset is the publicly available Phishing Email dataset (data/raw/Phishing_Email.csv). It contains real-world email bodies with binary labels.

Class	Count	Share
Safe Email	11,322	60.7%
Phishing Email	7,328	39.3%
Total	18,650	100%

Columns used: Email Text (body) and Email Type (label). No subject line or headers are available; detection relies entirely on body content. An 80/20 stratified train/test split (random_state=42) yields approximately 14,920 training and 3,730 test examples. All six configurations are evaluated on the same test set.

3. System Architecture

Module	Responsibility
src/data/loader.py	CSV ingestion, column renaming, label encoding, stratified split
src/data/preprocessor.py	Text cleaning, URL extraction via regex
src/detectors/rule_based.py	Weighted pattern-matching with five pattern categories and configurable weights
src/detectors/huggingface_detector.py	BERT phishing classifier wrapper
src/detectors/url_detector.py	Extracts URLs, scores against ~25 heuristic features, aggregates per-email risk
src/detectors/hybrid_detector.py	Weighted score fusion and strict consensus voting mode
src/evaluation/evaluator.py	Accuracy, precision, recall, F1, confusion matrix; saves CSV and TXT summaries
main.py	End-to-end pipeline: load → predict (6 configs) → evaluate → save results

3.1 Rule-Based Detector

Applies weighted regular-expression matching across five categories:

- Urgent language — "act now", "immediate action required" etc. (20 patterns, weight 2.0)
- Credential harvesting — requesting passwords, login, verification (9 patterns, weight 2.5)
- Suspicious phrases — prize offers, click-here bait, sign-in alerts (19 patterns, weight 1.5)
- Impersonation — brand names in a phishing context (8 patterns, weight 1.0)
- Spam/offer language — work-from-home, pharma terms (12+ patterns, weight 0.8)

A legitimate-context dampener subtracts score when mailing-list or academic markers are found. Final score is compared against threshold 1.4.

3.2 HuggingFace (BERT) Detector

Model: *ealvaradob/bert-finetuned-phishing* — BERT-base fine-tuned for phishing classification. Runs offline from local cache, truncates to 512 tokens, supports batched inference (batch_size=32).

3.3 URL Analyzer

Extracts URLs from the email body via multi-pattern regex and scores each against 25 heuristic features:

- Network/host: IP-as-hostname (+2.5), @ in netloc (+2.0), punycode (+2.0), URL shortener (+2.0), brand spoofing (+2.0)
- URL structure: very long URL ≥ 120 chars (+2.0), excessive encoding (+1.0), suspicious port (+1.5), open-redirect params (+1.8), suspicious path keywords (+1.4)
- TLD/domain: suspicious TLD (.zip, .tk, .xyz...) (+1.5), hyphens (+0.5), high digit ratio (+1.0), deep subdomain (+1.0)

Per-email score = maximum URL score. Emails with no URLs receive a default risk score of 0.3.

3.4 Hybrid Variants

Three hybrid strategies were implemented to systematically evaluate ensemble design choices:

Hybrid (Weighted) — all three components

$$\text{score} = 0.20 \times \text{rule} + 0.55 \times \text{BERT} + 0.25 \times \text{URL} \quad (\text{threshold} = 0.45)$$

Combines all three detectors. The BERT weight (0.55) reflects its superior accuracy. Serves as the primary hybrid configuration.

Strict Hybrid — consensus voting

Classifies as phishing only when at least two of the three detectors individually exceed a probability of 0.35. Designed to maximize precision by requiring corroborating evidence.

Hybrid (Rule+URL) — BERT-free ablation

$$\text{score} = 0.60 \times \text{rule} + 0.40 \times \text{URL} \quad (\text{threshold} = 0.50)$$

Intentionally excludes BERT to measure how much the two non-ML detectors achieve on their own. Acts as an ablation study confirming BERT's necessity in the ensemble.

4. Experimental Results

All six configurations were evaluated on the same held-out test set (3,727 emails: 2,265 legitimate + 1,462 phishing).

4.1 Performance Summary

Detector	Accuracy	Precision	Recall	F1 Score	TN	FP	FN	TP
Rule-Based	72.44%	81.03%	38.85%	52.52%	2132	133	894	568
HuggingFace (BERT)	97.80%	99.86%	94.53%	97.12%	2263	2	80	1382
URL Analyzer	50.55%	36.94%	36.87%	36.91%	1345	920	923	539
Hybrid (Weighted)	97.80%	99.86%	94.53%	97.12%	2263	2	80	1382
Strict Hybrid	67.70%	97.43%	18.13%	30.57%	2258	7	1197	265
Hybrid (Rule+URL)	61.42%	76.09%	2.39%	4.64%	2254	11	1427	35

4.2 Per-Detector Analysis

Rule-Based (Accuracy 72.4%, F1 52.5%)

Reasonable precision (81.0%) but low recall (38.9%): 894 of 1,462 phishing emails are missed. Characteristic of threshold-based heuristics — they catch overtly suspicious language but miss attacks that mimic legitimate communication. Only 133 false positives. Legitimate-context dampening helps suppress false alarms on Enron-style safe emails in the corpus.

HuggingFace (BERT) (Accuracy 97.8%, F1 97.1%)

The standout performer: only 2 false positives out of 2,265 legitimate emails and only 80 false negatives (5.5% miss rate). Purpose-trained on phishing data with contextual deep learning. The 512-token truncation may contribute to the small number of missed emails whose key signals appear late in the body.

URL Analyzer (Accuracy 50.6%, F1 36.9%)

Near-random performance with 920 false positives and 923 false negatives. The dataset contains many phishing emails with no URLs and many safe emails with superficially suspicious links (newsletters, commercial email). URL-only analysis is inherently limited on a text-centric corpus.

Hybrid (Weighted) (Accuracy 97.8%, F1 97.1%)

Identical results to standalone BERT — the confusion matrix is exactly the same (TN=2263, FP=2, FN=80, TP=1382). The BERT weight of 0.55 dominates: its high-confidence outputs move no predictions differently from BERT alone.

Strict Hybrid (Accuracy 67.7%, F1 30.6%)

Requiring consensus from at least two detectors cuts false positives to 7 (precision 97.4%) but collapses recall to 18.1% — 1,197 phishing emails are missed. The URL analyzer's consistent failure to flag phishing means consensus is rarely reached. Only appropriate where false positives are extremely costly.

Hybrid (Rule+URL) (Accuracy 61.4%, F1 4.6%)

The BERT-free ablation reveals the true contribution of the non-ML components: recall collapses to 2.4% and F1 to 4.6%. Only 35 of 1,462 phishing emails are caught. This definitively confirms that without BERT, the rule-based and URL detectors cannot compensate — and that URL analysis actively degrades the rule-based signal by dragging the ensemble score down on phishing emails that lack suspicious URLs.

4.3 Summary

Detector	Accuracy	F1	Speed	Interpretable	Dependencies	BERT?
Rule-Based	72.4%	52.5%	Very fast	Fully	None	No
BERT	97.8%	97.1%	Moderate	No	Transformers ~400MB	Yes
URL Analyzer	50.6%	36.9%	Fast	Fully	tlidextract	No
Hybrid (Weighted)	97.8%	97.1%	Moderate	Partial	All above	Yes
Strict Hybrid	67.7%	30.6%	Moderate	Partial	All above	Yes
Hybrid (Rule+URL)	61.4%	4.6%	Fast	Fully	tlidextract	No

5. Conclusions

The project successfully implements and compares six detection configurations. Key findings:

- The fine-tuned BERT model is the best single detector ($F1 = 97.1\%$), and the full weighted hybrid matches it exactly — confirming BERT's dominance in the ensemble.
- Rule-based detection is viable as a lightweight first-pass filter (precision 81%, no dependencies) but its recall ceiling ($\sim 39\%$) makes it insufficient alone.
- URL analysis alone is ineffective on this text-centric corpus. The Hybrid (Rule+URL) ablation shows it actively degrades the rule-based signal: F1 drops from 52.5% to 4.6% when URL replaces BERT.
- Strict Hybrid achieves the highest precision (97.4%) of any configuration, useful only when false positives are extremely costly and near-zero recall is acceptable.
- The Hybrid (Rule+URL) ablation is the most analytically valuable result: it quantifies exactly how much BERT contributes and confirms the rule-based and URL detectors cannot compensate for its absence.